
PERSONAL CYBERSECURITY LAB PROJECT

Website Security Assessment & Vulnerability Report

Target: OWASP Juice Shop

TARGET	OWASP Juice Shop
PROJECT TYPE	Personal Cybersecurity Lab Project
PREPARED BY	Rajih N.
DATE	09 September 2026

SECTION 1

Executive Summary

This assessment evaluated the security posture of OWASP Juice Shop running in a controlled local environment.

The assessment included reconnaissance, technology identification, HTTP header analysis, automated vulnerability scanning, and manual validation.

Several security observations were identified, including a missing Content Security Policy configuration and permissive CORS settings. Full details, severity ratings, and remediation guidance for each finding are provided in the sections that follow.

SECTION 2

Scope

Target	http://127.0.0.1:3000
Environment	Local Kali Linux testing environment
Testing Type	Black-box web application assessment

SECTION 3

Methodology

Testing followed these phases:

1. Target identification
2. Service enumeration
3. Technology fingerprinting
4. HTTP header analysis
5. Automated vulnerability scanning
6. Manual validation
7. Risk classification
8. Reporting

SECTION 4

Tools Used

- Kali Linux
- WhatWeb
- Nikto
- Nmap
- cURL
- OWASP ZAP

SECTION 5

Findings Summary Table

ID	Finding	Severity
WEB-01	Missing CSP Header	Medium
WEB-02	Permissive CORS	Low
WEB-03	Third-party JS Inclusion	Low
WEB-04	robots.txt Disclosure	Low

Detailed Findings

Finding WEB-01 — Missing CSP Header

Medium

Description

OWASP ZAP flagged the absence of a Content-Security-Policy header on the application's HTTP responses. Without a CSP, the browser has no explicit policy restricting the sources from which scripts, styles, and other resources may be loaded, which increases the potential impact of cross-site scripting (XSS) if such a flaw is present elsewhere in the application.

Finding WEB-02 — Permissive CORS

Low

Description

HTTP response header analysis identified a permissive Access-Control-Allow-Origin configuration. An overly broad CORS policy can allow web pages on other origins to make cross-domain requests to the application, which may expose data intended to be restricted to the same origin.

Finding WEB-03 — Third-party JS Inclusion

Low

Description

The application loads JavaScript resources from third-party/external domains. These resources are not hosted or controlled by the application and are not verified with Subresource Integrity (SRI), introducing a degree of supply-chain risk if any of those external sources were ever compromised.

Finding WEB-04 — robots.txt Disclosure

Low

Description

The robots.txt file discloses internal paths and endpoints not otherwise linked from the application's public pages. While intended to guide search engine crawlers, this file can also assist an attacker performing reconnaissance by revealing the existence of non-public routes.

SECTION 7

Recommendations

- Implement Content Security Policy (CSP) headers to restrict the sources of scripts, styles, and other content the browser is permitted to load.
- Restrict CORS policies to a defined allow-list of trusted origins rather than permitting broad or wildcard access.
- Review third-party JavaScript dependencies and consider Subresource Integrity (SRI) hashes to reduce supply-chain risk.
- Remove unnecessary information disclosure, such as internal paths listed in robots.txt, that could aid reconnaissance.

SECTION 8

Conclusion

The assessment identified several low-to-medium risk configuration issues within the OWASP Juice Shop deployment.

Applying the recommended security improvements — CSP enforcement, tighter CORS policy, third-party dependency review, and reduced information disclosure — would strengthen the application's overall security posture.